

# Anonymous Credentials from SD-JWT VC: Issuer-Unlinkable Nullifiers and Revocation in Transparent Zero-Knowledge

Jongho Han

Hopae

lukas@hopae.com · lukas.j.han@gmail.com

## Abstract

Selective-disclosure credentials—IETF *SD-JWT VC* and ISO *mdoc*—are being deployed at national scale in digital identity wallets, yet they provide *no unlinkability*: a static issuer signature over static salted hashes lets colluding verifiers, and the issuer itself, correlate a user’s presentations. The only standardized mitigation, *batch issuance*, provides verifier-unlinkability only and at a recurring per-presentation cost. Transparent, no-trusted-setup zero-knowledge can already prove possession of an *unmodified*, issuer-signed ECDSA credential with no change to issuers or devices—but *longfellow*, which introduced this, targets only ISO *mdoc* and offers no defense against linkable repeat use. We extend this line in three ways: (i) the **first zero-knowledge circuits for the unmodified IETF SD-JWT VC text format** (JSON/JWS/base64url); (ii) an **issuer-unlinkable per-context blind nullifier**—to our knowledge the first bound to an issuer-signed standard credential that *never de-anonymizes* its holder and is *publicly verifiable*, unlike PLUME/Semaphore nullifiers, Privacy Pass/ARC rate-limit tags, and e-cash double-spend tags; and (iii) signed-range non-membership revocation (mechanism due to *longfellow*) extended to SD-JWT VC. A shared, format-agnostic seam lets the new nullifier and revocation run *unchanged over both* SD-JWT VC and ISO *mdoc*. On *longfellow-zk*, a presentation proves in under 2 s and verifies in under 0.85 s on a commodity desktop ( $\approx 1.0$  s / 0.45 s for *mdoc*), with no trusted setup; the issuer-untraceable nullifier costs under 5% on SD-JWT VC ( $\approx 5\%$  on *mdoc*) over a plain nullifier.

**Keywords:** anonymous credentials; SD-JWT VC; ISO *mdoc*; transparent zero-knowledge; issuer-unlinkable nullifier; selective disclosure; unlinkability; revocation; eIDAS.

## 1 Introduction

Digital identity wallets are moving from pilots to law. The European Digital Identity (eIDAS 2.0) framework obliges member states to offer wallets to all citizens [11], and mobile driver’s licenses (mDL) are rolling out across U.S. states [1]. Two credential formats dominate these deployments: **IETF SD-JWT VC** [25], a JSON/JWS credential with salted-hash selective disclosure, and **ISO/IEC 18013-5 mdoc** [16], its CBOR counterpart. Both let a holder reveal a subset of attributes (e.g., *age*  $\geq 18$ ) while hiding the rest.

**The problem: selective disclosure is not unlinkability.** Hiding *which* attributes are shown does not hide *who* is showing them. In both formats the issuer signs a fixed set of salted attribute hashes, and the holder forwards that issuer signature, verbatim, to every relying party. The signature and the salted hashes are therefore stable identifiers: any two relying parties that compare notes—or

the issuer colluding with a relying party—can link a user’s interactions, and the issuer, who produced the signature, can recognize it anywhere. A standards-body taxonomy makes the distinction explicit, separating *verifier*-unlinkability from full *issuer*-unlinkability and noting that the salted-hash formats provide neither natively [9]. A statement signed by sixteen cryptographers warned the EU that this design “cannot ensure unlinkability,” which eIDAS 2.0 lists as a mandatory requirement [2].

**The state of practice is unsatisfying.** The only mitigation standardized today—across OpenID4VCI, RFC 9901, the High-Assurance Interoperability Profile, and the EUDI reference framework [18, 12, 19, 10]—is *batch issuance*: the issuer mints many single-use credentials, each with fresh salts and key-binding keys, and the holder spends one per presentation. This buys only *verifier*-unlinkability—the issuer can still correlate—at a recurring cost in issuance, storage, and key management, and it fails outright once a credential is reused. Cryptographic alternatives exist but each asks issuers to abandon their deployed credential: BBS#-style anonymous-credential signatures [8] require a new signature scheme (and issuer assistance at presentation), while SNARK-based systems that prove possession of an existing credential—Crescent [20], zk-creds [23]—depend on a circuit-specific *trusted setup* whose compromise silently breaks soundness. None of these targets the SD-JWT VC format that wallets are actually shipping.

**Our approach.** We make *unmodified* SD-JWT VC and ISO mdoc credentials unlinkable by proving their possession in **transparent zero-knowledge**—an argument system (Ligero + sumcheck) that needs no common reference string and rests only on SHA-256, building on longfellow [13]. The issuer keeps signing ordinary ECDSA credentials; the holder, at presentation, produces a proof that reveals only the attributes it chooses, the truth of a predicate, a per-context pseudonymous tag, and an epoch-fresh non-revocation fact—nothing else, and to no one, including the issuer. Within this framework we contribute the missing primitive that batch issuance and prior ZK systems lack: a nullifier that even the issuer cannot trace.

**An issuer-unlinkable blind nullifier.** A nullifier is a per-context tag that lets a verifier detect repeat use (one vote per election, one account per service) without identifying the holder. Existing constructions either reveal the holder on reuse (e-cash, zk-creds clone-resistance), are computed from a self-held key with no issuer-signed credential behind them (PLUME, Semaphore), or are privately verifiable so the issuer is a co-verifier (Privacy Pass/ARC). We instead have the *holder* commit a secret  $s$  at issuance— $C = \text{SHA256}(s||r)$ , which the issuer signs as an ordinary disclosure without ever seeing  $s$ —and derive the per-context nullifier  $N = \text{SHA256}(s||ctx)$  inside the proof, binding  $N$  to the same  $s$  the credential committed to. Because the issuer’s only view of the seed is the hiding commitment  $C$ , it cannot recompute or recognize  $N$ : the nullifier is *issuer-untraceable* (Theorem 10). To our knowledge this is the first issuer-unlinkable nullifier bound to an unmodified, publicly verifiable standard credential, and—being SHA-256 throughout—it adds no cryptographic assumption beyond the base proof system.

## Contributions.

- **(C1)** The first transparent, no-trusted-setup zero-knowledge construction over the **unmodified IETF SD-JWT VC** format—new circuits for its JSON/JWS/base64url/salted-hash structure, sharing a format-agnostic seam with ISO mdoc (§4).
- **(C2)** An **issuer-unlinkable per-context blind nullifier** bound to a standard credential, with a security definition and proof of issuer-untraceability (§6), and a precise separation from

PLUME, Semaphore, Privacy Pass/ARC, and e-cash (§8).

- **(C3) A single framework** unifying selective disclosure, attribute predicates, the blind nullifier, and signed-range non-membership revocation over *both* SD-JWT VC and mdoc (§4). We adopt the signed-range revocation *mechanism* from longfellow and contribute its extension to SD-JWT VC and its integration.
- **(C4) An implementation** on longfellow-zk and an evaluation showing the system runs with no issuer/device changes and no trusted setup, at practical cost (§7).

**Results.** On a commodity desktop, every configuration proves in under 2s and verifies in under 0.85s ( $\approx 1.0\text{s} / 0.45\text{s}$  for mdoc), with  $\approx 390\text{KB}$  (SD-JWT VC) and  $\approx 350\text{KB}$  (mdoc) proofs. The issuer-untraceable blind nullifier costs under 5% on SD-JWT VC ( $\approx 5\%$  on mdoc) over a plain nullifier, with no increase in proof size, and signed-range revocation adds a constant overhead independent of the revocation-list size. We also quantify, for the first time, the in-circuit cost of SD-JWT VC’s text encoding: its base64url/JSON parsing roughly doubles the hash-circuit work relative to mdoc’s CBOR.

## 2 Background

We recall the two credential formats, the linkability notion we target, and the transparent argument we build on.

**SD-JWT VC.** A JWS over a payload carrying `_sd`, an array of disclosure digests, and a holder-binding key in `cnf`; each disclosure is `base64url(JSON([salt, name, value]))` bound by `SHA256(disclosure) ∈ _sd`.

**ISO mdoc.** A CBOR credential whose Mobile Security Object signs salted device-namespace attribute hashes under ECDSA-P256.

**Linkability model.** Following [9] we distinguish *verifier*-unlinkability (relying parties cannot correlate) from *issuer*-unlinkability (the issuer cannot correlate); *full* unlinkability requires both.

**Transparent zero-knowledge.** longfellow [13, 14] combines the Liger MPC-in-the-head argument with a sumcheck verifiable-computation protocol; it has *no common reference string* and relies only on SHA-256, with Fiat–Shamir in the random-oracle model.

## 3 Threat Model and Security Goals

### 3.1 System model and parties

The system has three roles. An **issuer**  $\mathcal{I}$  holds a signing key  $(isk, ipk)$  and issues standard credentials (SD-JWT VC or mdoc) by signing a set of salted attribute hashes together with a holder-binding public key. A **holder**  $\mathcal{H}$  stores a credential and acts as prover. A **verifier**  $\mathcal{V}$  checks a presentation against a public statement (disclosed attributes, a predicate  $\phi$ , a presentation context  $ctx$ , and current revocation information). Revocation information is published by a **certificate-revocation authority**  $\mathcal{C}$  (possibly  $\mathcal{I}$ ) as signed *gaps* between adjacent revoked identifiers. A **presentation context**  $ctx$  is a public string scoping a nullifier; the nullifier is per-context.

**Context authorization (a requirement for unlinkability).** Since  $N = H_{\text{nul}}(s, ctx)$  collides exactly when  $ctx$  collides, cross-scope unlinkability is a property of the  $ctx$  discipline, not of the proof alone, and we require two things of it. (i) *Domain separation*:  $ctx$  binds the verifier’s scope, so distinct scopes yield independent nullifiers. (ii) *Authorization*: the wallet accepts a  $ctx$  only from a party that can demonstrate authority over that scope; a  $ctx$  presented by an unauthorized party is treated as an attempt to link and is ignored. Under this discipline a repeat presentation to the *same verifier under the same scope* deliberately yields the same  $N$ —the duplication signal the application relies on (one vote per election, one account per service)—while no other party can induce that collision. Whether that signal is persistent or periodic is the application’s choice of  $ctx$  granularity: an epoch-free  $ctx$  deduplicates a scope indefinitely (one account per service), whereas folding an epoch into  $ctx$  confines dedup to one period and refreshes it thereafter (one vote per election)—so the epoch is an optional namespace knob, not part of domain separation, which needs only the scope. This authorization is not new infrastructure: it is the verifier (relying-party) authentication that OpenID4VP and the EUDI ARF [10] already require—e.g., a relying-party registration certificate scoping what a verifier may request—so the wallet binds  $ctx$  to that authenticated, registered identity and rejects a  $ctx$  asserted by any other origin.

### 3.2 Trust and adversary model

- **No trusted setup.** The scheme is transparent: the only public parameters are a collision-resistant hash  $H$  (SHA-256, modeled as a random oracle for Fiat-Shamir) and a commitment scheme. There is no common reference string and hence no toxic waste; soundness rests on no party having to honestly discard a trapdoor. This is the central distinction from Groth16-based schemes, whose soundness additionally requires the integrity of a circuit-specific setup.
- **Issuer.** Honest at issuance but treated as an adversary for unlinkability: it may later collude with verifiers and use everything it observed at issuance, including the blind-nullifier commitments it signed. Its signing key is not compromised.
- **Verifiers.** May be malicious and may collude with one another and with the issuer.
- **Holder.** A malicious holder may try to forge a presentation, satisfy a predicate it does not, or present twice under one context with distinct nullifiers.
- Channels are confidential; the holder-binding key is held in a secure element and proven in zero knowledge, never revealed.

### 3.3 Security goals (informal)

1. **Completeness.**
2. **Soundness / credential unforgeability.**
3. **Selective-disclosure zero-knowledge.**
4. **Unlinkability** (verifier and issuer).
5. **Nullifier determinism & uniqueness.**
6. **Issuer-untraceability of the nullifier** ( $\star$ ).
7. **Revocation soundness & privacy.**

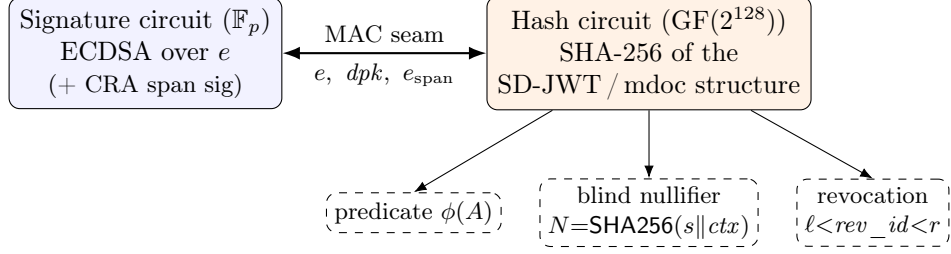


Figure 1: Split-circuit architecture. A signature circuit ( $\mathbb{F}_p$ ) and a hash circuit ( $\text{GF}(2^{128})$ ) are linked by a MAC over the shared values  $e, dpk, e_{\text{span}}$ ; the format-agnostic feature blocks (predicate, issuer-unlinkable blind nullifier, signed-range revocation) attach to the hash circuit and run unchanged for SD-JWT VC and mdoc.

**Uniqueness scope and issuance assumption.** Goal 5 is *per credential*: one credential yields one nullifier per context. Because issuance is blind, the issuer never sees the seed  $s$  and cannot enforce that a person holds only one, so a holder with  $k$  credentials produces  $k$  independent nullifiers. Sybil-resistance applications (e.g., one vote per election) therefore rest on the standard assumption that the issuer issues *one credential per person*—an identified, out-of-band step the issuer already controls—after which per-credential uniqueness *is* per-person uniqueness and the nullifier deduplicates that credential’s re-presentations within a context. Making  $s$  person-unique without the issuer learning it (e.g., deriving  $s$  in the secure element, or an issuer-side deterministic tag proven equal to  $s$  in zero-knowledge) is an alternative we leave to future work.

## 4 Construction

### 4.1 Overview

Our prover convinces a verifier, in transparent zero-knowledge, that it holds an issuer-signed standard credential satisfying a public statement, while revealing only the disclosed attributes, the truth of a predicate, a per-context nullifier, and an epoch-pinned non-revocation fact. We build on longfellow’s transparent argument (Ligero + sumcheck, SHA-256 only) and its *split-circuit* architecture, which we (i) drive from the IETF SD-JWT VC wire format, (ii) extend with an issuer-unlinkable blind nullifier, and (iii) combine with signed-range non-membership revocation—the same three feature blocks running unmodified over ISO mdoc through a shared seam (§4.6). Every gadget is expressed in SHA-256 and P-256 ECDSA, so no assumption beyond longfellow’s is introduced.

### 4.2 Split-circuit seam

Proving ECDSA and SHA-256 in a single field is wasteful: ECDSA arithmetic lives in the P-256 base field  $\mathbb{F}_p$ , whereas SHA-256’s bit operations are cheap over  $\text{GF}(2^{128})$ . Following longfellow, we use *two circuits in their native fields*—a signature circuit over  $\mathbb{F}_p$  that verifies the issuer’s ECDSA signature, and a hash circuit over  $\text{GF}(2^{128})$  that recomputes the SHA-256 structure—*linked by a MAC* over the values they share:  $e$  (the digest the issuer signs),  $dpk_x, dpk_y$  (the holder-binding key), and, with revocation,  $e_{\text{span}}$ . The prover commits its half  $a_p$  of a  $\text{GF}(2^{128})$  MAC key and the shared values *before* the Fiat–Shamir challenge reveals  $a_v$ ; the resulting MACs are public inputs to both circuits. By Schwartz–Zippel, a prover cannot feed two different values to the two circuits except with negligible probability. This seam is shared by all feature configurations (Figure 1).

### 4.3 SD-JWT VC front-end

The signature circuit verifies *two* ECDSA signatures: the issuer’s ES256 over the payload digest  $e$ , and the holder’s key-binding-JWT signature over its digest  $e_2$  under the device key  $dpk$ . The hash circuit recomputes, in-circuit: (a) the SD-JWT structure and  $e$ , (b) for each presented disclosure, its base64url decoding and membership of its digest in `_sd`, and (c) the key-binding JWT payload (its digest  $e_2$ , and the verifier’s `nonce/aud`). Each requested claim is handled in one of two modes: *disclose*—the value is matched against a public pattern and revealed—or *assert*—the value stays hidden and pinned to a verifier-chosen value (an *equality* predicate). A shared bitwise comparator enforces the *range* checks the format already needs—`now ≤ exp` on expiry and  $\ell < rev\_id < r$  on revocation; exposing it as a general range or set-membership predicate over arbitrary attributes is future work. The device key  $dpk$  is checked in-circuit to equal the issuer-attested `cnf` key, and the holder’s signature over  $e_2$  is verified (but, like  $dpk$  itself, never revealed): a valid presentation therefore *requires the holder’s secure-element key* (§6.2) while leaking no linkable handle. Both ECDSA verifications—the issuer’s and the holder’s—are the signature half measured in Table 2.

### 4.4 Issuer-unlinkable blind nullifier

This is our central construction. The goal is a per-context tag  $N$  that is unique per credential within a context, unlinkable across contexts, and untraceable even by the issuer.

**Why this is not textbook commit-and-prove.** The gadget—commit  $s$  at issuance, prove  $N = H_{\text{nul}}(s, ctx)$  at showing—is deliberately simple; the contribution is the regime. Untraceable prior nullifiers avoid an issuer altogether (PLUME’s self-held key, Semaphore’s admin-known leaf), making untraceability vacuous; ours binds to a credential that a real, later-adversarial issuer signed—its signature covering the commitment—yet still cannot link. Two constraints make this nontrivial: the commitment must be *blind* (an ordinary issuer-signed `_sd` disclosure the issuer never opens), and the seed must be bound end-to-end in SHA-256 only—from the issuer’s signature, through the payload digest  $e$  that the split-circuit seam carries (§4.2), down to the *same*  $s$  wires that open  $C$  and derive  $N$  (steps 4–5)—with no trusted setup. A single-field Groth16 (zk-creds, Semaphore) avoids the seam but only by reintroducing the setup we remove.

**Issuance (blind).** The *holder* samples a 256-bit seed  $s$  and a 256-bit blind  $r$  and forms a hash commitment  $C = \text{SHA256}(s||r)$  (written abstractly as `Commit( $s$ ;  $r$ )` in §6). The issuer signs  $C$  as an ordinary disclosure (`pseudonym_commitment`) included in `_sd`; it commits to  $C$ —the holder cannot later swap it—*yet never observes  $s$  or  $r$* . This is the issuer’s *existing* SD-JWT issuance, unchanged: `pseudonym_commitment` is an ordinary `_sd` disclosure whose value is holder-supplied—just as the holder-binding `cnf` key is a holder-supplied value the issuer already attests. No signing logic, key, signature scheme, or infrastructure changes; the claim set gains one entry, and the issuer need not even validate  $C$ , since a malformed commitment only prevents its own holder from later opening it.

**Presentation.** For a verifier-chosen context the prover takes  $ctx\_hash = \text{SHA256}(ctx)$  as a public input and proves, in zero-knowledge:

1. *membership* —  $\text{SHA256}(\text{commitment disclosure}) \in \text{\_sd}$ ;
2. *structure* — the disclosure decodes to the JSON triple `[salt, "pseudonym_commitment", C]`;
3. *decoding* — the base64url value decodes to the 32-byte  $C$ ;

4. *opening* —  $\text{SHA256}(s\|r)$  equals  $C$ ;
5. *nullifier* —  $N = \text{SHA256}(s\|ctx\_hash)$ , from the *same*  $s$  wires as the opening.

The only public outputs are  $ctx\_hash$  and  $N$ ; the commitment, disclosure, seed, and blind remain hidden. Sharing the  $s$  wires between steps 4 and 5 binds the value the issuer committed to exactly the value inside the nullifier.

**Why this is issuer-untraceable.** The issuer’s entire view of the seed is the hiding commitment  $C = \text{SHA256}(s\|r)$ ; with a 256-bit random  $r$  and SHA-256 modeled as a random oracle,  $C$  reveals nothing about  $s$ , so  $N$  is pseudorandom from the issuer’s view (Theorem 10). Because both the commitment and the nullifier are SHA-256, the blind nullifier adds *no* assumption beyond longfellow’s. This distinguishes it from PLUME/Semaphore (no issuer-signed credential), ARC (privately verifiable), and e-cash serial numbers (de-anonymize on reuse); see §8. Untraceability requires the holder to sample  $s$  at full entropy: a low-entropy seed would let an issuer who knows the holder brute-force  $N$ , but—like a malformed  $C$ —this harms only that holder.

#### 4.5 Signed-range non-membership revocation

We adopt longfellow’s signed-range mechanism and extend it to SD-JWT VC; we claim the *extension and integration*, not the mechanism. A revocation authority sorts the revoked identifiers and signs the open gaps between adjacent revoked ids as spans  $epoch\|\ell\|r$ . The credential carries a hidden `revocation_id` (its `_sd` digest `rev_id`). To prove non-revocation the holder presents one signed span with  $\ell < rev\_id < r$ . In-circuit, the CRA’s ECDSA signature over  $e_{\text{span}} = \text{SHA256}(epoch\|\ell\|r)$  is verified in the signature circuit;  $e_{\text{span}}$  is bound to the hash circuit by a fourth MAC;  $epoch$  is a public freshness pin; and  $\ell < rev\_id < r$  is checked bitwise. The proof size is *constant regardless of the revocation-list size* and reveals neither `rev_id` nor which gap was used. The holder’s proof is thus  $O(1)$  in the list size, but the CRA signs  $O(|\text{revoked}|)$  gaps and re-signs them each epoch—an issuance-side cost borne by the authority, off the presentation path.

#### 4.6 Unification across SD-JWT VC and mdoc

The seam and feature blocks are format-agnostic: they operate on the shared values and issuer-committed digests, not on the surface encoding. Only the front-end differs—SD-JWT VC parses `JWS/base64url/_sd`, whereas mdoc parses `CBOR/MSO/salted hashes`. Consequently the blind-nullifier and revocation blocks are identical across formats, and one shared implementation is the source of truth for both. Table 1 makes this concrete: the two formats verify the *same* in-circuit checks—including the device-key signature that binds each presentation to the holder’s secure element—and differ only in parsing, which is also the source of the runtime gap (§7).

#### 4.7 The full presentation

A complete presentation bundles the signature- and hash-circuit proofs (and, with revocation, the CRA span proof) with the public statement  $x = (ipk, ctx, N, D, \phi, rinfo)$  of §6.2, establishing all clauses of the relation  $\mathcal{R}$  with no trusted setup.

### 5 Implementation

We implement the system in C++ on top of longfellow-zk. A single shared header is the source of truth for the split-circuit seam (§4.2)—the MAC machinery, the public-input layout, and the

Table 1: What the circuit verifies, by format. The checks are identical; only the parsing front-end differs.

| Check                              | SD-JWT VC                | ISO mdoc                                |
|------------------------------------|--------------------------|-----------------------------------------|
| Issuer ECDSA                       | over JWS hash $e$        | over MSO hash $e$                       |
| Device ECDSA (holder)              | KB-JWT over $e_2$        | session transcript over $e_2$           |
| Device key attested                | $dpk = \text{cnf}$       | $dpk = \text{deviceKey}$                |
| Disclosure membership              | $\text{digest} \in \_sd$ | $\text{digest} \in \text{valueDigests}$ |
| Predicate / nullifier / revocation | identical feature blocks |                                         |
| Parsing front-end                  | JWS, base64url, JSON     | CBOR, MSO                               |

compiled-circuit cache—while a thin per-format front-end parses SD-JWT VC or mdoc and each feature is an additive circuit block. The four configurations per format (base, nullifier, blind nullifier, revocation) thus share one codebase, and the SD-JWT VC and mdoc variants differ only in their front-end. ECDSA verification reuses longfellow’s P-256 circuit and SHA-256 its flat-witness gadget, so the blind nullifier’s commitment and tag reduce to two extra SHA-256 blocks (§4.4). Circuits are compiled once and cached (zstd-compressed) so that proving and verification do not pay the build cost. An evaluation harness regenerates the issuer/holder fixtures and records the numbers reported in §7.

## 6 Security Analysis

### 6.1 Building blocks and assumptions

- **Issuer signature** Sig over the credential (ECDSA-P256), EUF-CMA (ECDSA in GGM+ROM).
- **Commitment** COM, computationally hiding and binding, *instantiated as a SHA-256 hash commitment*  $C = \text{SHA256}(s\|r)$  with a 256-bit blind (§4.4): hiding holds in the ROM, binding by collision resistance—so it adds no assumption beyond longfellow’s.
- **Nullifier hash**  $H_{\text{nul}}$ :  $N = H_{\text{nul}}(s, ctx)$ , *instantiated as*  $\text{SHA256}(s\|ctx\_hash)$  with  $ctx\_hash = \text{SHA256}(ctx)$  (§4.4), modeled as a random oracle / PRF keyed by  $s$ .
- **Transparent argument** NIZK (Ligero + sumcheck, Fiat–Shamir in the ROM), knowledge-sound and zero-knowledge, no setup.
- **CRA signature** for revocation gaps, EUF-CMA.

### 6.2 The presentation relation

A presentation is a NIZK for the relation  $\mathcal{R}$  on public statement  $x = (ipk, ctx, N, D, \phi, rinfo)$  and witness  $w = (cred, \sigma, \sigma_{kb}, dpk, s, r, A, \pi_{\text{rev}})$ .  $\mathcal{R}(x, w) = 1$  iff:

1.  $\text{SigVer}(ipk, cred, \sigma) = 1$  — valid issuer signature over the unmodified standard credential;
2. (*device binding*)  $\text{SigVer}(dpk, e_2, \sigma_{kb}) = 1$  and  $dpk$  equals the holder-binding key the issuer attested in  $cred$  ( $\text{cnf}$  for SD-JWT VC,  $\text{deviceKey}$  for mdoc), where  $e_2$  binds the presentation session (the KB-JWT, resp. the session transcript); a valid presentation therefore requires the device’s secure-element key;
3. a signed attribute equals  $C = \text{Commit}(s; r)$ ;



4.  $N = H_{\text{nul}}(s, ctx)$ ;
5.  $D$  is consistent with  $cred$  and  $A \supseteq D$ ;
6.  $\phi(A) = 1$ ;
7.  $\ell < rev\_id < r$  for a CRA-signed gap  $(\ell, r)$  in  $rinfo$ .

The statement reveals only  $N$  and  $ctx$  (plus  $D, \phi, rinfo$ );  $\sigma, C, s, r$ , the holder-binding key,  $rev\_id$ , and the chosen gap remain hidden.

### 6.3 Definitions and theorems

We state each property as a game;  $\text{negl}$  is negligible in the security parameter  $\lambda$ . Proof sketches are given here; the two load-bearing games (credential soundness and issuer-untraceability) are restated in pseudocode with fuller proofs in Appendix A.

**Theorem 1** (Completeness). *If  $cred$  is validly issued, non-revoked, and satisfies  $(D, \phi)$ , an honest prover convinces the verifier with probability  $1 - \text{negl}(\lambda)$ .*

*Proof sketch.* Immediate from completeness of NIZK.  $\square$

**Definition 2** (Credential soundness).  $\mathcal{A}$  gets  $ipk$  and an Issue oracle (recording  $Q$ ); it wins if it outputs an accepting  $(x^*, \pi^*)$  for which no issued  $cred \in Q$  both carries a valid signature and is consistent with  $x^*$ .

**Theorem 3.** *If NIZK is knowledge-sound, Sig is EUF-CMA, and COM is binding, then  $\Pr[\mathcal{A} \text{ wins}] \leq \text{negl}(\lambda)$ .*

*Proof sketch.* The extractor yields  $(cred^*, \sigma^*, s^*, r^*)$  with  $\mathcal{R}(x^*, \cdot) = 1$ ; if  $cred^* \notin Q$  this is an EUF-CMA forgery, otherwise consistency clauses (bound via the signature and commitment binding) contradict the win condition.  $\square$

**Definition 4** (Selective-disclosure ZK). There is a simulator  $\text{Sim}$  such that for every valid  $(x, w)$ , no PPT  $\mathcal{A}$  distinguishes  $\text{Prove}(x, w)$  from  $\text{Sim}(x)$ .

**Theorem 5.** *Follows from zero-knowledge of NIZK: a presentation is one proof for  $x$ , so it leaks nothing beyond  $x$ .*

**Definition 6** (Verifier-unlinkability). In a left-or-right game  $\mathcal{A}$  (colluding verifiers) chooses two non-revoked credentials equivalent on the challenge statement (same  $D$ , same  $\phi(A)$ , and a fresh challenge context  $ctx^*$ ); the challenger presents  $cred_b$ ;  $\mathcal{A}$  outputs  $b'$ .

**Theorem 7.** *Advantage  $\leq \text{negl}(\lambda)$  assuming NIZK is ZK, COM is hiding, and  $H_{\text{nul}}$  is a RO/PRF.*

*Proof sketch.* Hybrids: replace the proof by  $\text{Sim}(x)$  (ZK), which hides every witness—including the now credential-specific  $dpk$ , which is not in  $x$ ; the only  $b$ -dependent part of  $x$  is  $N_b$  (since  $D, \phi$  are equal by the restriction); replace  $N_b$  by a uniform value (fresh  $ctx^*$ , high-entropy  $s_b$ ), after which the view is independent of  $b$ .  $\square$

**Theorem 8** (Nullifier determinism & uniqueness).  *$N = H_{\text{nul}}(s, ctx)$  is deterministic in  $(s, ctx)$ , so two presentations of one credential under one context carry identical  $N$ ; and for  $s \neq s'$ ,  $\Pr[H_{\text{nul}}(s, ctx) = H_{\text{nul}}(s', ctx)] \leq \text{negl}(\lambda)$ . Binding of COM prevents opening  $C$  to a second seed within a context.*

*Scope.* Theorem 8 is per credential; one-per-person uniqueness additionally requires the issuance assumption of §3.3 (a holder with  $k$  credentials has  $k$  independent seeds, hence  $k$  nullifiers).

**Definition 9** (Issuer-untraceability  $\star$ ).  $\mathcal{A}$  is the issuer: it outputs  $ipk$  and runs  $q$  issuance sessions in which the honest holder sends  $C_j = \text{Commit}(s_j; r_j)$  and receives  $\mathcal{A}$ ’s signature.  $\mathcal{A}$  names two issued indices  $i_0, i_1$  and a fresh context  $ctx^*$ ; the challenger returns a presentation of  $i_b$  (with  $N_b = H_{\text{nul}}(s_{i_b}, ctx^*)$ );  $\mathcal{A}$  outputs  $b'$ . Issuer-untraceability holds if  $|\Pr[b' = b] - \frac{1}{2}| \leq \text{negl}(\lambda)$ .

**Theorem 10.** *If COM is hiding,  $H_{\text{nul}}$  is a RO/PRF, and NIZK is ZK, the scheme is issuer-untraceable.*

*Proof sketch.* Hybrids: (H1) replace the proof with  $\text{Sim}(x)$  (ZK); the issuer’s  $b$ -dependent view is  $C_{i_0}, C_{i_1}$  plus  $N_b, ctx^*$ . (H2) replace  $C_{i_0}, C_{i_1}$  by commitments to dummy values (hiding), making the issuance view independent of the true seeds. (H3) replace  $N_b$  by uniform: as  $\mathcal{A}$  never learns  $s_{i_b}$  and  $ctx^*$  is fresh, it cannot have queried the RO at  $(s_{i_b}, ctx^*)$  except negligibly. In H3 the view is independent of  $b$ .  $\square$

**Why prior nullifiers fail this game.** In zk-creds the clone-resistance tag *reveals* the holder on reuse; in zk-promises the serial number is a freshness token over a public commitment, not derived so the issuer cannot recompute it; in PLUME/Semaphore there is no issuer/commitment step (self-held key, resp. a public leaf the admin knows); in ARC verification uses the issuer’s secret key, so the issuer is a co-verifier. Our construction is, to our knowledge, the first to satisfy Definition 9 while binding to an unmodified, publicly verifiable standard credential.

**Definition 11** (Revocation soundness).  $\mathcal{A}$  wins if it produces an accepting presentation whose extracted  $rev\_id$  is in the revoked set for the epoch in  $rinfo$ .

**Theorem 12.** *If the CRA signature is EUF-CMA and NIZK is knowledge-sound,  $\Pr[\mathcal{A} \text{ wins}] \leq \text{negl}(\lambda)$ : the extractor yields a CRA-signed gap  $(\ell, r)$  with  $\ell < rev\_id < r$ , but no signed gap strictly contains a revoked  $id$ , so this is a CRA forgery.*

**Theorem 13** (Revocation privacy). *Neither  $rev\_id$  nor the chosen gap appears in  $x$ ; privacy follows from Theorem 5.*

## 6.4 Remarks and limitations

Our soundness reduces to EUF-CMA of standard ECDSA, binding of COM, and knowledge-soundness of a hash-based argument (ROM)—*no setup-integrity assumption*, unlike Groth16-based schemes. The reduction is stated for the relation  $\mathcal{R}$  and further assumes the circuits faithfully encode  $\mathcal{R}$ —notably the base64url/JSON and CBOR parsers—which we check by test vectors and differential testing against reference parsers, not formal verification (an orthogonal assurance shared by all circuit-based ZK systems). Issuer-untraceability assumes the issuer issues a well-formed signature (a malicious issuer can refuse service or mark a credential—out of scope, as for all surveyed schemes). We prove possession of a static credential; stateful properties (reputation, asynchronous bans) are out of scope by design. Non-interactivity and the nullifier model rely on the random oracle.

## 7 Evaluation

### 7.1 Setup and methodology

We implement all circuits on longfellow-zk (C++) and measure on a single commodity desktop—an AMD Ryzen 7 2700X (8 cores / 16 threads, 2018), 32 GB RAM, Linux, clang-17 -02. We report

Table 2: Per-feature cost on SD-JWT VC and ISO mdoc (median of 7 runs). The signature half verifies two ECDSA in every row (issuer over  $e$ , holder KB-JWT over  $e_2$ ); revocation adds a third, the CRA span.

| Format    | Feature              | Prove<br>(ms) | Verify<br>(ms) | Proof<br>(KB) | Hash inputs |
|-----------|----------------------|---------------|----------------|---------------|-------------|
| SD-JWT VC | base (SD + sig)      | 1961          | 796            | 391           | 195,386     |
| SD-JWT VC | + nullifier          | 1844          | 704            | 390           | 189,046     |
| SD-JWT VC | + <b>blind</b> null. | 1917          | 817            | 389           | 193,790     |
| SD-JWT VC | + revocation         | 1945          | 818            | 406           | 188,858     |
| ISO mdoc  | + nullifier          | 1003          | 432            | 345           | 95,590      |
| ISO mdoc  | + <b>blind</b> null. | 1057          | 475            | 347           | 100,078     |
| ISO mdoc  | + revocation         | 1033          | 459            | 361           | 95,402      |

the **median of 7 runs** after one warm-up; reported proving and verification times *exclude* the one-time circuit build. Because the proof system is transparent, there is no setup phase to amortize or trust, and no issuer or network interaction at presentation time. Each presentation comprises two MAC-linked proofs (signature over  $\mathbb{F}_p$ , hash over  $\text{GF}(2^{128})$ ); “proof” is the full transmitted bundle. We use a EUDI-style PID credential, disclosing one attribute (`age_over_18`) for the feature rows and three for the base row. The feature rows thus exercise selective disclosure rather than an attribute predicate; the in-circuit cost of a date-range predicate is nonetheless represented, since every row’s base already enforces `now ≤ exp` over the 10-digit expiry with the same comparator an `age_over_N` proof (`birth_date ≤ cutoff`) would reuse.

## 7.2 Results and analysis

Table 2 reports the measurements. *Practicality*: every configuration proves in under 2s and verifies in under 0.85s on a six-year-old desktop, with no trusted setup and no change to issuers or the credential. *Issuer-untraceability is essentially free*: comparing the apples-to-apples rows (both disclose one attribute), the blind nullifier adds only +73 ms (+4%) over a plain nullifier on SD-JWT VC and +54 ms (+5%) on mdoc, with no measurable change in proof size—the extra commitment-opening and nullifier are two SHA-256 blocks against the credential’s signature and disclosure hashing. *SD-JWT VC vs. mdoc*: mdoc is  $\approx 1.9\times$  faster, tracking hash-circuit size ( $\approx 95\text{k}$  vs.  $\approx 190\text{k}$  inputs); SD-JWT VC’s base64url/JSON parsing roughly doubles the SHA-256 work relative to mdoc’s CBOR—the first concrete quantification of this cost. (We omit a standalone mdoc base row: the nullifier block adds under 6%, so an mdoc base lies within a few percent of the +nullifier figure.) *Revocation* adds constant, list-independent overhead. Every row’s signature circuit already verifies *two* ECDSA—the issuer’s over  $e$  and the holder’s KB-JWT over  $e_2$  (§4.3). Each in-circuit P-256 ECDSA costs  $\approx 1,549$  signature-circuit inputs (the increment the CRA span adds), so the 3,739-input base is two such verifications plus  $\approx 640$  fixed overhead; a single ECDSA would leave an implausible  $\approx 2,190$  of overhead. Revocation adds a *third* ECDSA, growing the circuit to 5,288 inputs and the bundle by  $\approx 15\text{KB}$ , while prove/verify move within noise. *Proof size* is  $\approx 390\text{KB}$  (SD-JWT VC) /  $\approx 350\text{KB}$  (mdoc), split into roughly equal signature and hash halves—larger than pairing-based SNARKs, but requiring no trusted setup.

Table 3: Mobile prover: Samsung Galaxy Z Flip5 (Snapdragon 8 Gen 2, 8 GB), median of 7 with configuration order counterbalanced (rotated each round) to remove thermal-ordering bias. Peak RSS is the proof system’s working set and matches the desktop (Table 2’s hardware) within noise.

| Format    | Feature              | Prove<br>(ms) | Verify<br>(ms) | Proof<br>(KB) | Peak RSS<br>(MB) |
|-----------|----------------------|---------------|----------------|---------------|------------------|
| SD-JWT VC | base (SD + sig)      | 1299          | 593            | 392           | 372              |
| SD-JWT VC | + nullifier          | 1392          | 660            | 393           | 395              |
| SD-JWT VC | + <b>blind</b> null. | 1414          | 663            | 396           | 403              |
| SD-JWT VC | + revocation         | 1442          | 692            | 415           | 397              |
| ISO mdoc  | + nullifier          | 694           | 331            | 344           | 180              |
| ISO mdoc  | + <b>blind</b> null. | 731           | 361            | 347           | 187              |
| ISO mdoc  | + revocation         | 757           | 364            | 361           | 182              |

Table 4: Cost to support  $k$  unlinkable presentations from one logical credential (analytical). Batch issuance trades cheap presentations for  $O(k)$  issuance/storage and issuer-linkability; we trade a per-presentation proof for  $O(1)$  issuance and full unlinkability.

|                               | Batch issuance               | This work                                          |
|-------------------------------|------------------------------|----------------------------------------------------|
| Issuer signatures (issuance)  | $k$                          | 1                                                  |
| Holder storage                | $k$ credentials              | 1 credential                                       |
| Holder per-presentation       | forward sig. ( $\approx 0$ ) | 1 ZK proof ( $\approx 1\text{--}2\text{ s}$ )      |
| Verifier per-presentation     | 1 sig. verify                | 1 ZK verify ( $\approx 0.5\text{--}0.8\text{ s}$ ) |
| Issuer online at presentation | no                           | no                                                 |
| Unlinkability                 | verifier only                | verifier + issuer                                  |
| Presentations beyond $k$      | linkable / must refill       | unbounded                                          |

### 7.3 Mobile prover

We re-ran the full evaluation on a **Samsung Galaxy Z Flip5** (Snapdragon 8 Gen 2 for Galaxy, 8 GB RAM) under Termux with identical circuits. A compact foldable throttles under sustained load, and a fixed configuration order then inflates the later runs by  $\approx 30\%$ ; Table 3 therefore reports the median of seven rounds with the order *counterbalanced* (rotated each round), which removes that bias. *Mobile proving is practical*: every configuration proves in under 1.5 s and verifies in under 0.7 s—faster than the 2018 desktop across the board ( $1.3\text{--}1.5\times$ )—and the SD-JWT-VC- $\approx 2\times$ -mdoc ratio (§7) holds on-device. *Memory is platform-independent*: peak resident set is 180–410 MB, essentially identical to the desktop (180–199 MB mdoc, 383–414 MB SD-JWT VC)—it is the Ligerio tableau, not a platform artifact—about 5% of the phone’s 8 GB. Per-feature differences on mobile stay within thermal variance; we isolate feature costs on the desktop (Table 2), and the base row (three disclosed attributes vs. one) is not feature-comparable.

### 7.4 Comparison to batch issuance

Batch issuance moves all cost to issuance and storage: to support  $k$  verifier-unlinkable presentations the issuer mints and signs  $k$  single-use credentials and the holder stores them, while each presentation is a cheap signature check. Our approach inverts this: a single credential supports an unbounded number of unlinkable presentations, each a  $\approx 1\text{--}2\text{ s}$  proof with no issuer interaction. Beyond cost, the two differ in privacy: batch issuance yields only verifier-unlinkability and leaves the issuer able to correlate, whereas our presentations are unlinkable to the issuer as well (Theorem 10).

Table 4 summarizes the trade. Batch issuance is cheaper per presentation but bounded: once the  $k$  pre-issued credentials are spent the holder must re-provision, and the issuer can still correlate across presentations. We instead pay a per-presentation proof, but issuance and storage are  $O(1)$ , presentations are unbounded, and unlinkability extends to the issuer.

## 7.5 Threats to validity

Measurements span an x86 desktop and a Snapdragon 8 Gen 2 phone (§7.3); a server-class datapoint remains future work. Proving time scales with the number and size of disclosed attributes; we fix a representative PID disclosure. Reported sizes are circuit input counts (a proxy for circuit size), not raw gate counts. Numbers reflect the implementation as of the submission date.

## 8 Related Work

We compare prior approaches along the axes that define our contribution: the proof system and whether it requires a trusted setup; the credential format (an *unmodified deployed standard* credential vs. a bespoke structure); selective disclosure and predicates; unlinkability (verifier vs. issuer); whether a nullifier is provided and if so whether it is *issuer-untraceable*; and revocation. Table 5 summarizes.

### 8.1 Zero-knowledge over existing standard credentials

**Longfellow** [13] is the first transparent system to prove possession of legacy ECDSA(P-256) credentials with no change to issuers or devices, relying only on SHA-256 [14]. But its paper and implementation target ISO mdoc only (a plain-JWT circuit was added later); neither addresses SD-JWT VC, and it builds no nullifier. We build on the same proof system but construct the first SD-JWT VC circuits, add an issuer-unlinkable blind nullifier, and unify both formats; we credit the signed-range revocation *mechanism* to longfellow. **Crescent** [20] adds unlinkability to generic JWT and mDL via a prepare/show model, but its main proof is a **Groth16** zk-SNARK requiring a circuit-specific trusted setup, and it targets generic JWT rather than the SD-JWT VC standard. **zk-creds** [23] converts e-passports into anonymous credentials by re-committing to a Merkle issuance list on a bulletin board (Groth16, trusted setup; its clone-resistance tag de-anonymizes on reuse), and **zk-promises** [24] generalizes this to stateful credentials with serial-number nullifiers for replay; both require bulletin-board infrastructure and trusted setup over re-committed state, not an unmodified credential. **Mombelli** [17] is the closest prior work to target SD-JWT VC directly, but—finding in-circuit parsing of a real SD-JWT prohibitive ( $>1.2\text{M}$  constraints for a 1 KB credential)—it has the *issuer* re-issue the credential with extra signed claims: a Poseidon Merkle-tree root over the attributes plus a *second* ECDSA-secp256k1 signature, replacing SHA-256 and P-256 with circuit-friendly primitives (evaluated mainly under Groth16/PLONK). This requires issuer-side modification and new (Poseidon, secp256k1) assumptions, and its inter-credential linking value `cred_bind` is a per-subject string the issuer knows—the opposite of an issuer-untraceable nullifier. We instead verify the genuine SHA-256 `_sd` digests and the original P-256 signature of an *unmodified* SD-JWT VC, add no algebraic assumption, and bind an issuer-untraceable nullifier. **Cinderella** [7] verifies X.509/RSA certificates in a Pinocchio SNARK with a per-policy trusted setup.

### 8.2 Anonymous-credential signature schemes

**CL/Idemix** [5, 6] (Strong-RSA, multi-show unlinkable) and **U-Prove** [3, 21] (DL, one-show; reuse is linkable) design new signatures, as do **BBS/BBS+** and the recent **BBS#** [8], which is pairing-

Table 5: Comparison of approaches to privacy-preserving credential presentation. N = no trusted setup (transparent), T = trusted setup; V/I = verifier/issuer unlinkability; ✓/✗/∼ = yes/no/partial.

| System                    | Proof system           | Setup          | Format                  | SD       | Pred                 | Unlink (V/I) | Nullifier (issuer-untraceable?) | Revocation                      | PubVerif |
|---------------------------|------------------------|----------------|-------------------------|----------|----------------------|--------------|---------------------------------|---------------------------------|----------|
| Batch issuance (baseline) | —                      | —              | SD-JWT/mdoc             | ✓        | ✗                    | V/✗          | ✗                               | status list                     | ✓        |
| Longfellow [13]           | Ligero+sumcheck        | N              | mdoc(+JWT)              | ✓        | ∼                    | ✓/✓          | ✗                               | signed-range <sup>a</sup>       | ✓        |
| Crescent [20]             | Groth16(+Spartan)      | T              | generic JWT/mDL         | ✓        | ∼                    | ✓/✓          | ✗                               | —                               | ✓        |
| Mombelli [17]             | Groth16/PLONK          | T <sup>d</sup> | SD-JWT→extended         | ✓        | ✓                    | ✓/✓          | ✗cred_bind, issuer-known        | —                               | ✓        |
| zk-creds [23]             | Groth16+LinkG16        | T              | e-passport→recommit     | ✓        | ✓                    | ✓/✓          | ∼de-anon on reuse               | list removal                    | ✓        |
| zk-promises [24]          | Groth16                | T              | account state           | —        | ✓                    | ✓/✓          | serial (replay)                 | callback                        | ✓        |
| BBS# [8]                  | BBS+Schnorr NIZK       | N <sup>b</sup> | own BBS-family          | ✓        | ✓                    | ✓/✓          | pseudonym                       | accumulator                     | ∼        |
| Idemix [6]                | CL / Strong-RSA        | T              | own                     | ✓        | ✓                    | ✓/✓          | pseudonym                       | accumulator                     | ✓        |
| U-Prove [3]               | Brands / DL            | ∼              | own token               | ✓        | ✓                    | ✗one-show    | —                               | token revoke                    | ✓        |
| Cinderella [7]            | Pinocchio SNARK        | T              | X.509/RSA               | ∼        | ✓                    | ✓/✓          | ✗                               | —                               | ✓        |
| PLUME [15]                | EC-VRF                 | N              | self-held secp256k1     | —        | —                    | ✓            | ✓(no issuer)                    | —                               | ✓        |
| Semaphore [22]            | Groth16                | T              | own Merkle group        | —        | —                    | ✓            | ✗admin knows leaf               | —                               | ✓        |
| ARC [26]                  | KVAC (MACGGM)          | N              | own MACGGM              | ✗        | ✗                    | ✓/∼          | ∼per-ctx, weak                  | —                               | ✗priv    |
| Compact e-cash [4]        | CL / Strong-RSA        | T              | own coin                | —        | —                    | ✓            | ✗de-anon on dbl-spend           | —                               | ✓        |
| <b>This work</b>          | <b>Ligero+sumcheck</b> | <b>N</b>       | <b>SD-JWT VC + mdoc</b> | <b>✓</b> | <b>∼<sup>c</sup></b> | <b>✓/✓</b>   | <b>✓issuer-untraceable</b>      | <b>signed-range<sup>a</sup></b> | <b>✓</b> |

<sup>a</sup>Revocation mechanism due to longfellow; we extend it to SD-JWT VC. <sup>b</sup>BBS# NIZK needs no setup but requires issuer interaction at presentation. <sup>c</sup>Predicates: equality assertion plus the format’s built-in date ranges (expiry, revocation); general range/set-membership over arbitrary attributes is future work. <sup>d</sup>Mombelli also evaluates transparent backends; the credential modification (Poseidon root + second secp256k1 signature) is issuer-side and backend-independent.

free, eIDAS-2-targeted, and offers full issuer-unlinkability and accumulator revocation. Sixteen cryptographers recommended the BBS family for the EUDI Wallet, noting salted-hash formats “cannot ensure unlinkability” [2]. Every scheme here binds to *its own* format: deploying it requires issuers to adopt a new signature, and BBS# requires issuer assistance at presentation. We instead leave the deployed, ECDSA-signed credential unchanged.

### 8.3 Nullifiers and rate-limiting tokens

**Semaphore** [22] derives a per-scope nullifier but binds to a bespoke Merkle group whose leaves the admin knows, and uses Groth16. **PLUME** [15] derives a deterministic nullifier from a self-held secp256k1 key—transparent, but with no issuer and no credential. **Privacy Pass ARC** [26] is the closest match on the mechanism (a per-context tag, claimed Issuer–Client unlinkable) but binds only to its own MACGGM (KVAC) credential and is *privately verifiable*—the issuer and origin share a secret key and tokens are “not publicly verifiable.” In **compact e-cash** [4] a coin’s serial number is issuer-unlinkable only while honest and *de-anonymizes the spender on double-spend*. Our blind nullifier never de-anonymizes.

### 8.4 Unlinkability for deployed SD-JWT VC and mdoc

In standardized systems the only mechanism today is *batch issuance* [18, 12, 19, 10], which provides only verifier-unlinkability at a recurring per-presentation cost [9].

### 8.5 Positioning

As Table 5 shows, no prior system simultaneously (i) requires no trusted setup, (ii) operates over an unmodified deployed standard credential (both SD-JWT VC and mdoc), and (iii) provides an issuer-untraceable nullifier with public verifiability. Our framework occupies the remaining cell.

## 9 Discussion and Limitations

**Scope.** We prove possession of a *static* credential. Stateful anonymous-credential features—reputation, asynchronous bans, revocable pseudonyms—as in zk-promises are out of scope by design; our target is the single-shot presentation that wallets actually perform.

**Assumptions.** Soundness reduces to EUF-CMA of standard ECDSA, binding of the SHA-256 commitment, and knowledge-soundness of a hash-based argument in the random-oracle model; unlike Groth16-based systems there is no setup-integrity assumption. The random-oracle heuristic underlies both Fiat–Shamir and the blind nullifier. Our theorems are asymptotic; concretely we adopt longfellow’s v7 Ligerio parameters—132 columns opened at rate 1/7 over  $\text{GF}(2^{128})$ , reported at  $\approx 109$ -bit statistical soundness [13, 14]—atop SHA-256 Merkle commitments and Fiat–Shamir in the ROM, and do not re-derive these bounds. As longfellow is recent, that concrete analysis has a short cryptanalytic track record—an inherited caveat we state rather than resolve.

**Proof size.** Transparent (hash-based) proofs are larger ( $\approx 350$ – $390$  KB) than pairing-based SNARKs; this is the price of removing the trusted setup. At this size a proof does not fit a QR code; presentment assumes a return channel (NFC, BLE, or an HTTPS callback), as mDL already uses—though an HTTPS callback exposes IP/TLS metadata, a linkage vector outside our cryptographic model that proximity channels (NFC/BLE) avoid. Reducing proof size (e.g., via recursion or a succinct wrapper) is future work.

**Honest issuance.** Issuer-untraceability treats the issuer as adversarial *after* issuance but assumes it issues a well-formed signature; a malicious issuer can always refuse service or mark a credential—an orthogonal problem shared by all surveyed schemes.

**Measurement and moving target.** Numbers are from an x86 desktop and a Snapdragon 8 Gen 2 phone (§7.3); a server-class datapoint remains future work. longfellow evolves upstream (a plain-JWT circuit was added recently); our SD-JWT VC results should be re-confirmed against the version cited at submission.

## 10 Conclusion

Selective-disclosure credentials are shipping without the unlinkability their own governing frameworks require. We showed that transparent, no-trusted-setup zero-knowledge can turn *unmodified* SD-JWT VC and ISO mdoc credentials into anonymous credentials—unifying selective disclosure, predicates, an issuer-unlinkable blind nullifier, and signed-range revocation in one framework over both formats—at practical cost (sub-2s proving, sub-second verification) and with no change to issuers or devices. The blind nullifier, which even the issuer cannot trace yet which costs only  $\approx 5\%$  over a plain nullifier, closes the gap that batch issuance and prior zero-knowledge systems leave open.

## A Pseudocode games and full proofs

We restate the two load-bearing properties as games and give fuller proofs; the remaining properties (Theorems 1, 5, 8, 12, 13) follow from the body sketches.

### Game Snd (credential soundness).

1. The challenger runs issuer key generation  $(isk, ipk)$ , gives  $ipk$  to  $\mathcal{A}$ , and sets  $Q \leftarrow \emptyset$ .
2.  $\mathcal{A}$  may query **Issue**( $\cdot$ ): the challenger signs the requested credential body, returns the credential, and adds it to  $Q$ .
3.  $\mathcal{A}$  outputs  $(x^*, \pi^*)$  and wins iff  $\text{Ver}(x^*, \pi^*) = 1$  and no  $cred \in Q$  is both validly signed and consistent with  $x^*$  (disclosed values, predicate, device binding, non-revocation).

*Full proof of Theorem 3.* Let  $\mathcal{A}$  win Snd with probability  $\epsilon$ . By knowledge-soundness of NIZK there is an extractor  $\mathcal{E}$  that, from  $\mathcal{A}$ 's accepting  $(x^*, \pi^*)$ , outputs a witness  $w^* = (cred^*, \sigma^*, \sigma_{kb}^*, dpk^*, s^*, r^*, A^*, \pi_{rev}^*)$  with  $\mathcal{R}(x^*, w^*) = 1$  up to knowledge error  $\kappa$ . Clause 1 of  $\mathcal{R}$  gives  $\text{SigVer}(ipk, cred^*, \sigma^*) = 1$ , and clause 2 a valid holder signature  $\sigma_{kb}^*$  under  $dpk^*$ , the holder-binding key attested in  $cred^*$ . Two cases. (i)  $cred^* \notin Q$ : then  $(cred^*, \sigma^*)$  is a valid forgery; an EUF-CMA adversary that relays **Issue** queries to its signing oracle and outputs  $(cred^*, \sigma^*)$  wins with probability  $\epsilon - \kappa$ . (ii)  $cred^* \in Q$ : then  $cred^*$  is validly signed, and the remaining clauses bind the disclosed values, the predicate output, the committed nullifier seed (via binding of COM), the device key (clause 2:  $dpk^*$  equals the attested **cnf/deviceKey** and carries a valid  $\sigma_{kb}^*$ ), and the non-revocation fact to  $cred^*$ ; hence  $cred^*$  is consistent with  $x^*$ , contradicting the win condition unless COM-binding is broken (probability  $\leq \beta$ ). Therefore  $\epsilon \leq \text{Adv}^{\text{euf}} + \beta + \kappa$ , which is negligible.  $\square$

### Game Untr (issuer-untraceability).

1.  $\mathcal{A}$ , playing the issuer, outputs  $ipk$ .
2. For  $j = 1, \dots, q$  the honest holder samples  $s_j, r_j \leftarrow \{0, 1\}^{256}$  and sends  $C_j = \text{SHA256}(s_j \| r_j)$ ;  $\mathcal{A}$  returns a signature on a credential embedding  $C_j$  (or aborts session  $j$ ).
3.  $\mathcal{A}$  outputs two completed indices  $i_0, i_1$  and a context  $ctx^*$  not previously used by  $i_0$  or  $i_1$ .
4. The challenger picks  $b \leftarrow \{0, 1\}$  and returns a presentation of credential  $i_b$  under  $ctx^*$ , including  $N_b = \text{SHA256}(s_{i_b} \| \text{SHA256}(ctx^*))$ .
5.  $\mathcal{A}$  outputs  $b'$  and wins iff  $b' = b$ .

*Full proof of Theorem 10.* We bound  $\mathcal{A}$ 's advantage by hybrids.  $H_0$  is the real game.  $H_1$  replaces the challenge presentation's proof by  $\text{Sim}(x)$  for  $x = (ipk, \text{SHA256}(ctx^*), N_b, D, \phi, \text{rinfo})$ ; by zero-knowledge  $|\Pr[H_0] - \Pr[H_1]| \leq \text{Adv}^{\text{zk}}$ , and now the only  $b$ -dependent values in  $\mathcal{A}$ 's view are the issuance commitments  $C_{i_0}, C_{i_1}$  and the tag  $N_b$ .  $H_2$  replaces  $C_{i_0}, C_{i_1}$  with  $\text{SHA256}$  of independent uniform strings; by hiding of the SHA-256 commitment in the ROM (each  $r_i$  is a fresh 256-bit value)  $|\Pr[H_1] - \Pr[H_2]| \leq 2 \text{Adv}^{\text{hide}}$ , after which  $\mathcal{A}$ 's issuance view is independent of the true seeds.  $H_3$  replaces  $N_b$  by a uniform 256-bit string. In  $H_2$  the seed  $s_{i_b}$  is hidden from  $\mathcal{A}$ , so it queries the random oracle at  $(s_{i_b} \| \text{SHA256}(ctx^*))$  with probability at most  $q_H/2^{256}$ ; absent that query  $N_b$  is uniform, so  $|\Pr[H_2] - \Pr[H_3]| \leq q_H/2^{256}$ . In  $H_3$  the view is independent of  $b$ , hence  $\Pr[H_3] = \frac{1}{2}$ . Collecting terms, the advantage is at most  $\text{Adv}^{\text{zk}} + 2 \text{Adv}^{\text{hide}} + q_H/2^{256}$ , which is negligible.  $\square$

## References

- [1] AAMVA. Mobile driver's license (mDL) implementation guidelines, 2023.



- [2] Carsten Baum, Olivier Blazy, Jan Camenisch, Jaap-Henk Hoepman, Eysa Lee, Anja Lehmann, Anna Lysyanskaya, René Mayrhofer, Hart Montgomery, Ngoc Khanh Nguyen, Bart Preneel, abhi shelat, Daniel Slamanig, Stefano Tessaro, Søren Eller Thomsen, and Carmela Troncoso. Cryptographers’ feedback on the EU digital identity’s ARF. EU Digital Identity Wallet ARF GitHub Discussion #211, 2024.
- [3] Stefan A. Brands. *Rethinking Public Key Infrastructures and Digital Certificates: Building in Privacy*. MIT Press, 2000.
- [4] Jan Camenisch, Susan Hohenberger, and Anna Lysyanskaya. Compact E-Cash. In *EUROCRYPT*, 2005. IACR ePrint 2005/060.
- [5] Jan Camenisch and Anna Lysyanskaya. An efficient system for non-transferable anonymous credentials with optional anonymity revocation. In *EUROCRYPT*, 2001.
- [6] Jan Camenisch and Anna Lysyanskaya. A signature scheme with efficient protocols. In *Security in Communication Networks (SCN)*, 2002.
- [7] Antoine Delignat-Lavaud, Cédric Fournet, Markulf Kohlweiss, and Bryan Parno. Cinderella: Turning shabby X.509 certificates into elegant anonymous credentials with the magic of verifiable computation. In *IEEE Symposium on Security and Privacy (S&P)*, 2016.
- [8] Nicolas Desmoulins, Antoine Dumanois, Seyni Kane, and Jacques Traoré. Making BBS anonymous credentials eIDAS 2.0 compliant, 2025. Introduces BBS# / MACBBS. IACR ePrint 2025/619; see also NIST WPEC 2024.
- [9] ETSI. ETSI TR 119476-1: Electronic signatures and trust infrastructures; analysis of selective disclosure and unlinkability. Technical report, ETSI, 2025. V1.3.1.
- [10] European Commission. The European digital identity wallet architecture and reference framework (ARF), 2024.
- [11] European Parliament and Council. Regulation (EU) 2024/1183 amending regulation (EU) no 910/2014 as regards establishing the European digital identity framework, 2024.
- [12] Daniel Fett, Kristina Yasuda, and Brian Campbell. Selective disclosure for JSON web tokens (SD-JWT). RFC 9901, IETF (Internet Standard), 2025.
- [13] Matteo Frigo and abhi shelat. Anonymous credentials from ECDSA. *IACR Communications in Cryptology*, 2024. IACR ePrint 2024/2010.
- [14] Matteo Frigo and abhi shelat. libzk: A C++ library for zero-knowledge proofs. IETF Internet-Draft draft-google-cfrg-libzk-01 (expired; individual submission, Informational), 2024.
- [15] Aayush Gupta and Kobi Gurkan. PLUME: An ECDSA nullifier scheme for unique pseudonymity within zero knowledge proofs, 2022. IACR ePrint 2022/1255; ERC-7524.
- [16] ISO/IEC. ISO/IEC 18013-5: Personal identification — ISO-compliant driving licence — part 5: Mobile driving licence (mDL) application. Technical report, ISO/IEC, 2021.
- [17] Damiano Mombelli. General-purpose zero-knowledge proofs for verifiable credentials. Master’s thesis, ETH Zurich, Department of Computer Science, 2025. Advisors: K. G. Paterson and M. Burkhart.

- [18] OpenID Foundation. OpenID for verifiable credential issuance 1.0, 2025.
- [19] OpenID Foundation. OpenID4VC high assurance interoperability profile 1.0, 2025.
- [20] Christian Paquin, Guru-Vamsi Policharla, and Greg Zaverucha. Crescent: Stronger privacy for existing credentials, 2024. IACR ePrint 2024/2013.
- [21] Christian Paquin and Greg Zaverucha. U-Prove cryptographic specification V1.1 (revision 3). Technical report, Microsoft Research, 2013.
- [22] Privacy & Scaling Explorations. Semaphore: A zero-knowledge protocol for anonymous signaling. <https://semaphore.pse.dev>, 2024.
- [23] Michael Rosenberg, Jacob White, Christina Garman, and Ian Miers. zk-creds: Flexible anonymous credentials from zkSNARKs and existing identity infrastructure. In *IEEE Symposium on Security and Privacy (S&P)*, 2023. IACR ePrint 2022/878.
- [24] Maurice Shih, Michael Rosenberg, Hari Kailad, and Ian Miers. zk-promises: Anonymous moderation, reputation, and blocking from anonymous credentials with callbacks. In *USENIX Security Symposium*, 2025. IACR ePrint 2024/1260.
- [25] Oliver Terbu, Daniel Fett, and Brian Campbell. SD-JWT-based verifiable credentials (SD-JWT VC). IETF Internet-Draft draft-ietf-oauth-sd-jwt-vc, 2025.
- [26] Cathie Yun et al. The anonymous rate-limited credentials (ARC) protocol. IETF Internet-Draft draft-ietf-privacypass-arc-protocol, 2025.